ResearchGate

See discussions, stats, and author profiles for this publication at: https://www.researchgate.net/publication/298867330

# Mission oriented risk and design analysis of critical information systems

**Article** *in* MILITARY OPERATIONS RESEARCH · January 2005

CITATIONS
38

READS
707

**6 authors**, including:

Gregory S. Parnell
University of Arkansas
**151** PUBLICATIONS **1,863** CITATIONS

SEE PROFILE

O. Sami Saydjari
Cyber Defense Agency, Inc, Clarksville, United States
**29** PUBLICATIONS **603** CITATIONS

SEE PROFILE

**Some of the authors of this publication are also working on these related projects:**

Project Engineering Resilient Systems View project

Project Risk Management and Human Error Analysis for Recreational Boating View project

All content following this page was uploaded by Gregory S. Parnell on 12 July 2018.

The user has requested enhancement of the downloaded file.

# Mission Oriented Risk and Design Analysis of Critical Information Systems

**Donald L. Buckshaw**
*Innovative Decisions Inc.*
*dbuckshaw@innovativedecisions.com*

**Gregory S. Parnell, FS**
*Innovative Decisions Inc. and United States Military Academy*
*gregory.parnell@usma.edu*

**Willard L. Unkenholz**
*Department of Defense*

**Donald L. Parks**
*Department of Defense*

**James M. Wallner**
*Cyber Defense Agency*
*jwallner@cyberdefenseagency.com*

**O. Sami Saydjari**
*Cyber Defense Agency*
*ssaydjari@CyberDefenseAgency.com*

*APPLICATION AREA:*
Information Warfare
*OR METHODOLOGIES:*
Decision Analysis, Risk Analysis, Optimization

## ABSTRACT

Future military operations are becoming increasingly dependent on critical information systems. This paper describes a value-based information assurance methodology for Mission Oriented Risk and Design Analysis (MORDA) of information systems. The MORDA methodology was developed from 1998 to 2005 and has been successfully applied on seven major Department of Defense risk assessment studies, including a Joint Staff J6 mandated risk assessment of the Global Command and Control System. MORDA is a quantitative risk assessment and risk management process that uses risk analysis techniques and multiple objective decision analysis models to evaluate information system designs. MORDA models include adversary models; attacks trees; user models; service provider models; and integration and analysis models. The process provides a method for determining an optimum allocation of system design and operation resources that will ensure an operable information system in a hostile and malicious operating environment. MORDA uses subject matter expert teams from various disciplines to collect data and incorporates expert knowledge on adversaries, information systems technologies, and operation of the information system in the mission environment. The availability of key experts and cross-discipline teamwork are critical elements of the process.

## INTRODUCTION

Since information systems are the fundamental enabler of our national information infrastructure and of the Department of Defense's (DoD) Network Centric Operations (NCO), information assurance has become increasingly critical to the success of future military operations. Information Assurance is defined as activities that protect and defend information systems by ensuring their availability, integrity, authentication, confidentiality, and non-repudiation (JP 3-13, 1998). Information assurance requires a credible risk assessment and risk management approach that will deal effectively with life cycle threats to information systems and information. In information assurance, risk is the probability that the information system will not be able to perform its mission.

Because risk assessments are required for every DoD information system, the demand for risk assessment resources is high. Risk assessments are being performed in many organizations, but their methodologies are different and not coordinated. Risk assessments need to be of a sufficient quality to provide designers, certifiers, accreditors, and operational mission managers with the necessary information needed to make sound risk management decisions (DAWG, 2004).

The demand for high-quality risk assessments led us to develop a risk assessment method that was rigorous, credible, and responsive to the needs of information system owners, designers and operators as well as accreditors and certifiers. The purpose of this paper is to introduce a risk assessment and risk management process that evaluates our most critical national information systems.

## Need for a New Risk Methodology

The Joint Staff J6 tasked several DoD organizations to conduct a risk assessment of the Global Command and Control System (GCCS). GCCS is the warfighter's secret-level command and control system to support world-wide military operations. The GCCS is a suite of applications that reside on the Secret Internet Protocol Router Network (SIPRNET), a collection of Secret-level local area networks connected by a common communications backbone.

An important step within the risk assessment task was the need to determine the optimum set of countermeasures to be applied to the system to provide information assurance. Constraining the assessment was the need to operate within a budget and the desire to minimize potential mission impacts of countermeasures. For example, a firewall may increase security, but may limit the ability of the system to connect with an intelligence database. The key to this study was the ability to trade-off the security related benefits against the costs of countermeasures.

The organizations tasked to complete the risk assessment were challenged by the concepts of optimal countermeasures and

the trade-off between security benefits and mission degradation. In addition, the certifier of GCCS and the architect of GCCS had different objectives. The certifier was primarily interested in security aspects of the network, and less concerned with the user functions that the network provides. The architects were primarily concerned with an operational system and not security related functions required to ensure an operational network in a cyber conflict. For this assessment to succeed, a new method was needed that could account for security risk in a hostile environment, the mission impact of a successful attack, the effect of countermeasures on risk, and the potential mission degradation from countermeasures.

## Review of the Risk Literature

MORDA uses the theories of attack tree models; information assurance models; and multiple objective decision analysis. There exists a fair amount of literature on these topics.

*Attack Tree Models.* Unkenholz created a methodology of analyzing information system attacks using vulnerability trees, which were based on the fault trees developed in reliability theory. He introduced the concept of combining computer attack steps that exploit individual vulnerabilities into attacks using Boolean logic (Unkenholz, 1989). Amoroso described the use of similar fault trees (referred to as threat trees) for secure systems engineering and discussed a semi-quantitative method of scoring nodes of the tree based on criticality, effort, and risk (Amoroso, 1994). Lund, Unkenholz and Parks created the Risk Analysis Model based on Unkenholz's work by transforming the fault trees into event trees and documenting this probabilistic-based methodology (Lund et al., 1996). Salter, Saydjari, Schneier, and Wallner (1998) used attack trees in their secure engineering methodology and integrated the attack trees within a life cycle attack model. Schneier popularized the term attack tree in an on-line article (Schneier, 1999) and a book (Schneier, 2000). Moore, Ellison, and Linger described how attack trees are used at Carnegie Mellon Software Engineering Institute (2001).

*Qualitative Information Assurance Models.* McCumber introduced a model for information security that incorporated the three concepts of Information Characteristics, Information States, and Security Countermeasures (McCumber, 1991). Maconachy extended this model by expanding on the security services and introducing the concept of time thus expanding the focus from "information security" to "information assurance" (Maconachy et al., 2001).

*Quantitative Information Assurance Models.* Salter, Saydjari, Schneier, and Wallner developed a model for secure system engineering that included an adversary model and life cycle vulnerability model using attack trees. This methodology evaluates countermeasures in terms of security benefits, financial costs, and operational impact considerations (Salter et al., 1998). Soo Hoo put some decision analysis rigor to information assurance modeling by creating a probabilistic risk model using influence diagrams and the annual loss expectancy model (Soo Hoo, 2000). Stoneburner created a semi-quantitative risk methodology for the National Institute of Standards and Technology (NIST). The NIST method examines the network vulnerabilities and measures the risk according to threats, controls, likelihood, and impact (Stoneburner et al., 2001). The Information Assurance Technical Framework (IATF) introduced Mission Oriented Risk Analysis (MORA) and created a framework for a quantitative risk assessments using utility theory (IATF, 2002). Butler introduced the Security Attribution Evaluation Method (SAEM) which is a multi-attribute risk analysis used for structured cost-benefit analyses. SAEM uses value functions, swing weights, and frequency estimations to determine a threat index. Butler (2002) evaluated countermeasures based on percent effectiveness estimates and considered defense in depth.

*Multiple Objective Decision Analysis Models.* Keeney and Raiffa developed a formal prescriptive approach for solving complex decisions using multi-attribute utility (Keeney and Raiffa, 1976). This theory is especially suited for analyzing decisions with multiple, competing objectives. Keeney later introduced Value-Focused Thinking (VFT) as a method for replacing traditional alternative-focused thinking. VFT

espouses that values are more fundamental to a decision problem than alternatives (Keeney, 1992). Kirkwood provides a framework for making strategic decisions using quantitative spreadsheet-based decision multiple objective decision analysis models (Kirkwood, 1997).

*Multiple Objective Decision Analysis for Information Assurance.* Hamill introduced a VFT approach for identifying key information, generating information assurance strategies, and evaluating implementation measures (Hamill, 2000). He created a triad of value models addressing Information Assurance, Operational Capability, and Resource Costs. Subsequently, he used VFT to study how the value of information in an information system applies to risk management (Hamill et al., 2002). Beauregard expanded on Hamill's work, modifying the three models for a specific application. He also introduced uncertainty into the quantitative value model by having subject matter experts hypothesize a best and worst case for every data point (Beauregard et al., 2002).

## MISSION ORIENTED RISK AND DESIGN ANALYSIS (MORDA)

In order to satisfy the Joint Staff's need for a credible GCCS risk assessment the risk assessment team needed a new methodology. For the results to be accepted by the Joint Staff J6, this methodology needed to be mission-oriented and focused on the warfighter. We used the Information Assurance Technical Framework's (IATF) Mission Oriented Risk Assessment (MORA) process as a template for our methodology and incorporated the best techniques identified in our literature search. Risk assessments should be performed throughout the system life cycle. However, the MORA process did not specifically identify the need to conduct a risk assessment *before* a system was fielded. The ideal time to assess the risk and to implement cost effective changes is during design. Once fielded, we can only optimize countermeasures. So the team changed the acronym to MORDA to emphasize design changes to the system to affect mission accomplishment at any point in the life cycle.

Our risk and design analysis process is based on six foundational beliefs.

- Security threats to information systems and information are increasing and can occur throughout the system life cycle.
- The most cost-effective time to perform the risk assessment is during the information system design.
- Key subject matter experts and stakeholders must be involved in the risk assessment and management process.
- All security risk management decisions should consider the information system's ability to support the organization's mission operations in a hostile operating environment.
- Investment in security countermeasures can both help and hinder mission accomplishment.
- Risk analysts must provide decision-makers a comprehensive cost-benefit analysis that can balance system security, mission functionality, and resource costs.

The Security Optimization Countermeasure Risk and Threat Evaluation System (SOCRATES) is the model we have developed to implement the MORDA process (Figure 1). There are risk-based decisions that need to be made in each of these phases. The emphasis of this paper is on the critical "select design" phase but the MORDA process can be used in all phases. We discuss SOCRATES in the next section.

## SOCRATES MODEL

In order to support the MORDA methodology, the following modeling tasks need to be performed:

- Encourage subject matter experts to communicate with each other and explicitly define model assumptions, attack data, and countermeasure characterization
- Identify adversaries and their attack preference functions
- Identify and characterize adversary attacks
- Identify countermeasures and design alternatives

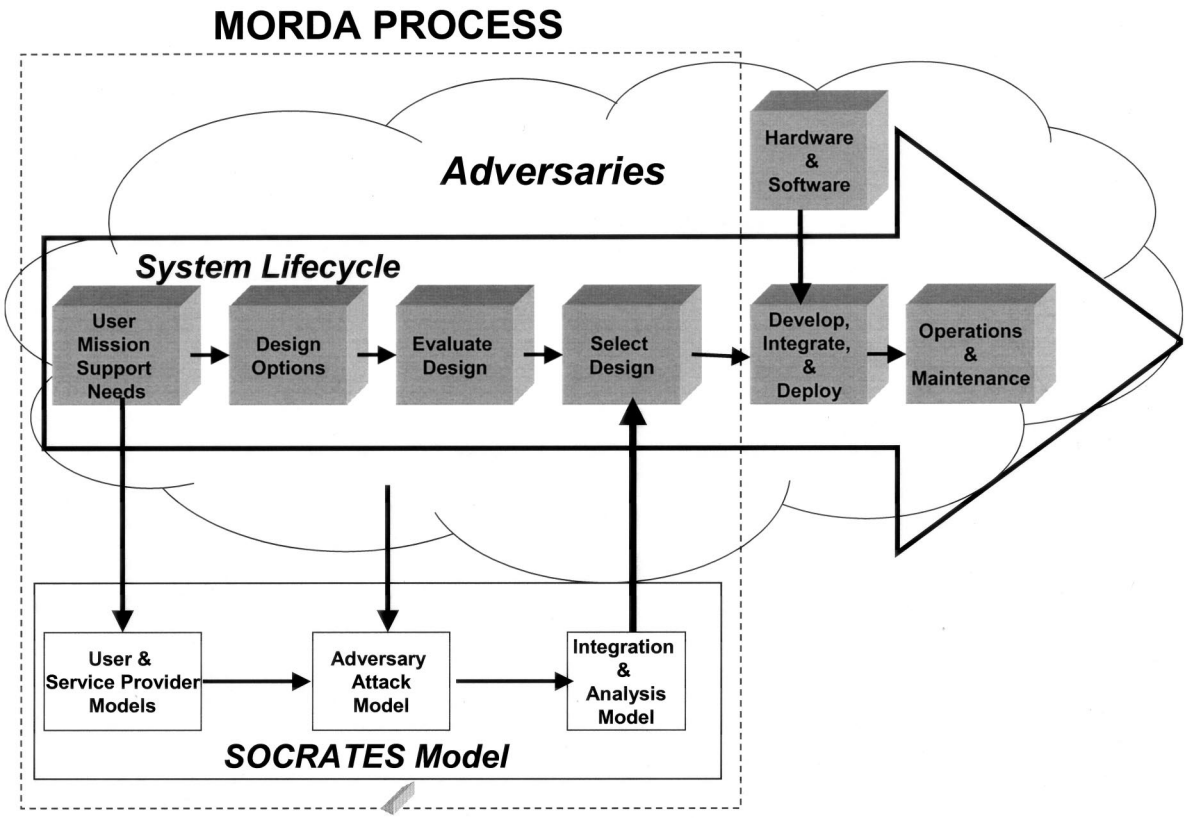



**Figure 1.** Mission Oriented Risk and Design Analysis (MORDA)

- Explicitly describe the security for each design alternative
- Account for non-security user and service provider concerns, such as functionality and interoperability
- Characterize decision-maker preference functions
- Account for the complex interdependencies of countermeasures and attacks
- Evaluate countermeasure effectiveness
- Allocate risk reducing resources

To meet these requirements in our MORDA process, the team developed the SOCRATES Model.

## Overview

SOCRATES is a quantitative risk assessment model and design optimization tool that is based on multiple objective decision analysis. The SOCRATES developers decided a value-based approach was required to capture both the countermeasure's ability to enhance the security of the network and the loss of operator value from degradation of User functions. In addition, a value approach allows the attack analysis experts to describe computer network attacks through qualitative labels that were later turned into quantitative scales. This approach provides a quantitative attack evaluation that does not rely on the adversary's probability of attack, a problem that has vexed risk analysts for years.

Figure 2 shows the SOCRATES model. SOCRATES combines adversary data, attack data, and countermeasure data into three value models: adversary, user, and service provider. Threat experts provide adversary data that characterizes the adversary's preference for different kinds of attacks based on how well the attacks satisfy the adversary's values. Security analysts provide attack data through attack trees and are characterized in qualitative terms

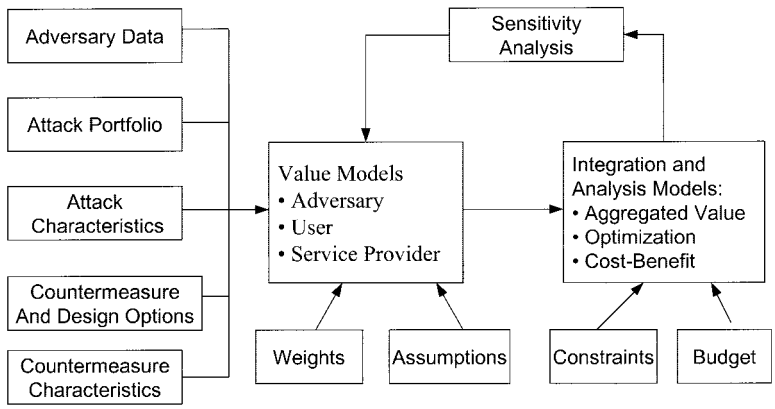



**Figure 2.** SOCRATES Model

for how likely the attack is to be detected, how likely it is that the attack will succeed if attempted, the resources required to execute the attack and what the impact of the attack would be if successfully executed. (These four questions are not intrinsic to the model; others can be used as appropriate.) System engineers provide countermeasure data describing which attacks they mitigate, how they mitigate the attacks, and to what degree they mitigate the attacks.

The Integration and Analysis Model maximizes the value of the system to the warfighter by ensuring an operable system in both peacetime and conflict. Financial cost models may also be included in this model. The model maximizes the value of the system by evaluating various countermeasure or alternatives designs. Three techniques have been used: aggregated value, optimization, and cost-benefit analysis. The goal is to minimize the value of a portfolio of attacks that the adversary possesses and minimize the negative effects of countermeasures on the user's mission during system operation. The value of the attacks to the adversary are mitigated to the point where the decision maker believes the best balance of risks and operational impacts are attained given the available resources.

## MORDA Uses Multiple Objective Decision Analysis

SOCRATES uses multiple objective decision analysis as the mathematical technique for several of the models. Multiple objective decision analysis is a prescriptive operations research technique to determine the best alternative when we have multiple, conflicting objectives (values) and significant uncertainties (Keeney and Raiffa, 1976; Watson and Buede, 1987; Kirkwood, 1997; and Parnell, 2005). In SOCRATES, we have developed several types of value models, e.g., an Adversary Value Model. Each value model starts with a value hierarchy that relates overall value goals to individual value measures. Alternatives are evaluated by scoring them on the individual value measures, converting the scores to standardized values using value functions and combining the standardized values into an overall value using a weighted sum. Mathematically, for each of the value models, we assume an additive model:

$$v(x) = \sum_{i=1}^{n} w_i v_i(x_i)$$

where

| | |
|---|---|
| $v(x)$ | is the value of the alternative |
| $i = 1$ *to* $n$ | is the number of the value measure |
| $x_i$ | is the score of the alternative on the $i^{\text{th}}$ value measure |
| $v_i(x_i)$ | is the single dimensional value of a score of $x_i$ |
| $w_i$ | is the weight of the $i^{\text{th}}$ value measure |
| and | $\Sigma_{i=1}^{n} w_i = 1$ (all weights sum to one) |

There are many techniques available to structure the value model objectives including the use of affinity diagraming (Parnell, 2005). Affinity diagraming is a brainstorming technique to develop the value hierarchy by sorting suggested measures by affinity (similarity). Value measures can be classified as direct or proxy and also as either natural or constructed (Kirkwood, 1997). A direct measure is used to directly assess how well an objective is accomplished, such as measuring the likelihood of successfully completing an attack using probabilities. A proxy scale is used to measure the equivalent attainment of the goal indirectly, such as measuring the complexity of an attack as a proxy for probability of success. A natural scale is an obvious choice for measurement that is generally agreed upon by everyone. Measuring financial or budgetary resources in terms of dollars is an example. A constructed scale is used if no natural scale exists, or if it is too hard to collect data for the natural scale. An example would be creating a constructed scale to measure the degree of difficulty of completing an attack. For each value measure in each model, we develop a single dimensional value function that captures the returns to scale on the value measure (Kirkwood, 1997).

Obtaining the value measure weights can be a difficult process and is easily done incorrectly. There are two different types of weights: importance weights and swing weights. Importance weights are used to reflect the general importance of one value measure over another without regard to the particular decision at hand. Swing weights reflect the importance of one value measure over another based on the relative importance of the swing in value of going from the worst possible level for a value measure to the best possible level (Watson and Buede, 1987). Swing weights are the proper weighting concept for value models. One useful method for generating swing methods is the balance beam method (Watson and Buede, 1987), (Buede, 1996) and (Kuskey 2000).

## MORDA is a Team Sport

MORDA requires teamwork from subject matter experts in various disciplines. These teams provide the data that SOCRATES uses and are essential to the success of the MORDA risk assessment process. The teams typically used and their expertises are:

- Adversary Team—Experts on the adversaries, their motivations, and their capabilities
- Attack Team—Experts on the vulnerabilities of the system and the attacks that exploit the vulnerabilities
- Customer Impact Team—Representatives of the user who understand how the system will be used and how the attacks and countermeasures affect the mission
- Architecture Team—System engineers who understand the basic design of the system
- Countermeasure Team—System engineers who understand possible technical or procedural countermeasures to mitigate the attacks
- Modeling Team—Decision and risk analysts that facilitate the data collection, develop the models, and perform the analysis

These teams must work closely together so they can understand how their team contributes to the overall effort. The teams are responsible for producing the data for their model(s). SOCRATES is typically implemented using the following models:

- Adversary Attack Model,
- User and System Provider Models, and
- Integration and Analysis Models

## ADVERSARY ATTACK MODEL

A major premise of MORDA is that it is more useful to measure the adversary's attack preferences instead of the adversary's probabilities of attack. Adversary attack preferences are easier to measure and help develop the mitigation strategy. We need to consider all attacks since a capable and adaptive threat will constantly change their actions in response to our assurance activities. This is very different from modeling the probability of an act of nature, such as a hurricane or earthquake. Once we know what the adversary values in an attack, we can then apply countermeasures to reduce the attack attractiveness to the adversary, thus reducing the likelihood of that attack. We as-

sume that any decrease in the adversary's value for a portfolio of attacks is approximately equivalent to a gain in the user's value. The complex interaction of countermeasures on the adversary's value model is a main difference between MORDA and other risk assessment techniques. The key to adversary model development is teamwork by the adversary team, the attack team and the modeling team.

## Adversaries

The adversary team must determine which adversaries to include in their model. The range of potential adversaries in the literature can be quite intimidating. Cohen, in his information system classification scheme, lists thirty-seven potential adversaries (Cohen, 1997). In general, all references agree on a basic set of adversaries; they differ in how specific adversary subsets should be grouped. We believe these adversaries can generally be divided into nine major adversary classes (Buckshaw et al., 2004):

- Foreign Intelligence Services (FIS)
- Information Warriors
- Cyber Terrorists/Activists
- Hackers/Crackers/Script Kiddies
- Malicious Insiders
- The Press
- Organized Crime/Lone Criminals
- Law Enforcement
- Industrial Competitors

In some cases, the model may be insensitive to several of these adversary classes. That is, the output of the model, which is a prioritized listing of countermeasures, may not change if certain adversaries are excluded from the analysis (Buckshaw et al., 2004). In general, this list will change from system to system and environment to environment. Often, the last four adversary classes listed above (the press, organized crime, law enforcement and industrial competitors) are not essential for risk assessments for critical national systems.

## Adversaries' Value Models

In order to apply decision analysis techniques, we assume that our adversaries behave in a rational manner with respect to their own preferences. Even adversaries that do not appear "rational" from a western culture value system, such as a suicide terrorist, can demonstrate rational actions relative to his/her preferences and value systems. Schneier (2000) states that "most adversaries are rational within their frames of reference" and "if the adversary is paying attention; he will choose an attack that minimizes his costs and maximizes his benefits." Our model assumes a rational adversary that will analyze a portfolio of computer network attacks and wisely choose attacks that are most beneficial to their cause.

The first step in value modeling is to determine the fundamental objective of the adversary. In this case the adversary's fundamental objective is to "determine the best attack." The adversary could have several purposes for the attack: to cause disruption, to capture information, to cause harm to the mission, or to enhance some mission of their own. We define the attack objectives that make them more or less desirable to the adversary. There are a large number of possible objectives that an adversary can have. In this case, we used four adversary objectives. The adversary wants to maximize their likelihood of successfully completing the attack, minimize the likelihood of detection given an attempt, minimize the resources required to execute the attack, and maximize the impact of the attack. For simplicity we assume that each adversary has the same value hierarchy. For each of these objectives, we develop a value measure and a value function. The adversaries may differ in their value functions and the weights they assign the value measures. Once agreed upon, these objectives form a value hierarchy as shown in Figure 3. The following paragraph explains this process in more detail.

Likelihood of Detection measures the likelihood that the system owner will detect an attack in progress. Ideally, we would like to use the probability of detection as our direct, natural scale. However, experience has shown that this information is not readily available, and experts are either reluctant or unable to provide estimates. Instead, we developed a constructed scale (Table 1).

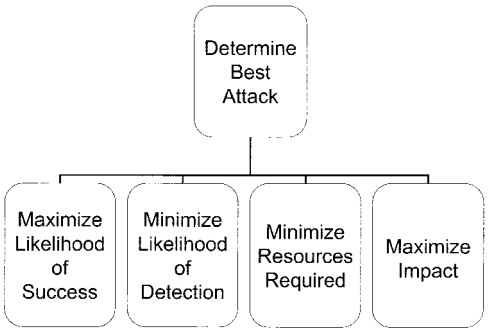



**Figure 3.** Adversary Value Hierarchy

Next, we constructed a single dimensional value function, so that the most desirable level from the adversary's perspective receives a "1" and the least attractive receives a "0." The value for a particular alternative gives the proportion of the distance that the alternative is from the hypothetical worst alternative with an overall value of "0" and the hypothetical ideal alternative with the overall value of "1" (Kirkwood, 1997). Alternatively, the scale can be reversed to demonstrate the value to the system owner.

The single dimensional value function is shown in Figure 4. We assume the FIS is very risk adverse meaning that they do not want their attack detected or attributed to them. Attacks that are very hard to detect will therefore score the highest and are more attractive to the adversary with respect to this parameter. An attack scoring "High" on the detection scale, for example, might only be attempted if that attack scores well on the value of all other measures.

We use the same value measure for this objective for every adversary. However, each adversary would require a single dimensional value function and different weights customized to their values and preferences. Each attack would be scored according to how well it meets the adversary's value model. Value functions would be created in a similar fashion for the other objectives.

## Adversaries' Attacks

Once we understand the adversary's preferences for various attack characteristics, we can model the attacks that they may use against our system. We define an attack as the minimum number of steps required to complete the adversary's objective. We use attack trees as a logical representation of the combinations of attack steps that form a complete attack. These steps are combined using the logical operators of "AND" and "OR" gates.

The creation of attack trees is an important part of the SOCRATES model. Attack trees have many desirable features for information system risk assessments. The construction of the attack tree will explicitly enumerate all attacks that the attack team identified. This is essentially a qualitative description of the vulnerabilities of the system that:

**Table 1.** Constructed Scale for the Minimize Likelihood of Detection Objective

| Level | Description | Example |
|---|---|---|
| Very Low | Passive attack with no footprint | Passively collecting traffic off a microwave link |
| Low | Leaves a footprint but no detection mechanism is looking for it | Installing a sniffer on a system in receive only mode |
| Low-Medium | Leaves a footprint; the detection mechanism is looking for it but will typically miss it | Detecting malicious software installed during the software development life cycle |
| Medium | Leaves a suspicious footprint, but may be attributed to normal behavior | Several unsuccessful logon attempts |
| High | Leaves an audit trail, readily identifiable as anomalous behavior | Logging in as System Administrator during unusual hours |
| Very High | Sets off an alarm; readily identifiable as an attack | Network flood attack |

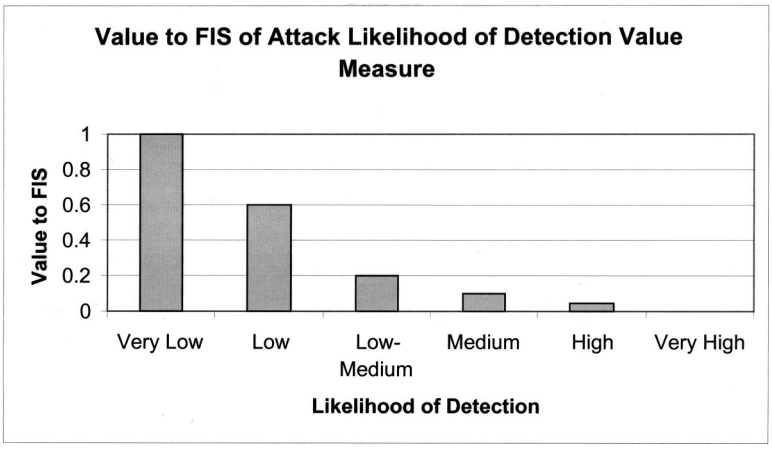



**Figure 4.** Single Dimensional Value Function of FIS for Likelihood of Detection

- Ensures team members understand exactly what defines an attack
- Maintains a historic log of what attacks were identified
- Helps identify new attacks
- Provides a resource for training and future efforts

Attack trees can become quite complex and should be created by system engineers (Lund et al., 1996). In practice, a member of the modeling team often facilitates a meeting with the security engineers and attack analysts. If possible, data sources such as security test and evaluation reports; red team reports; vulnerability

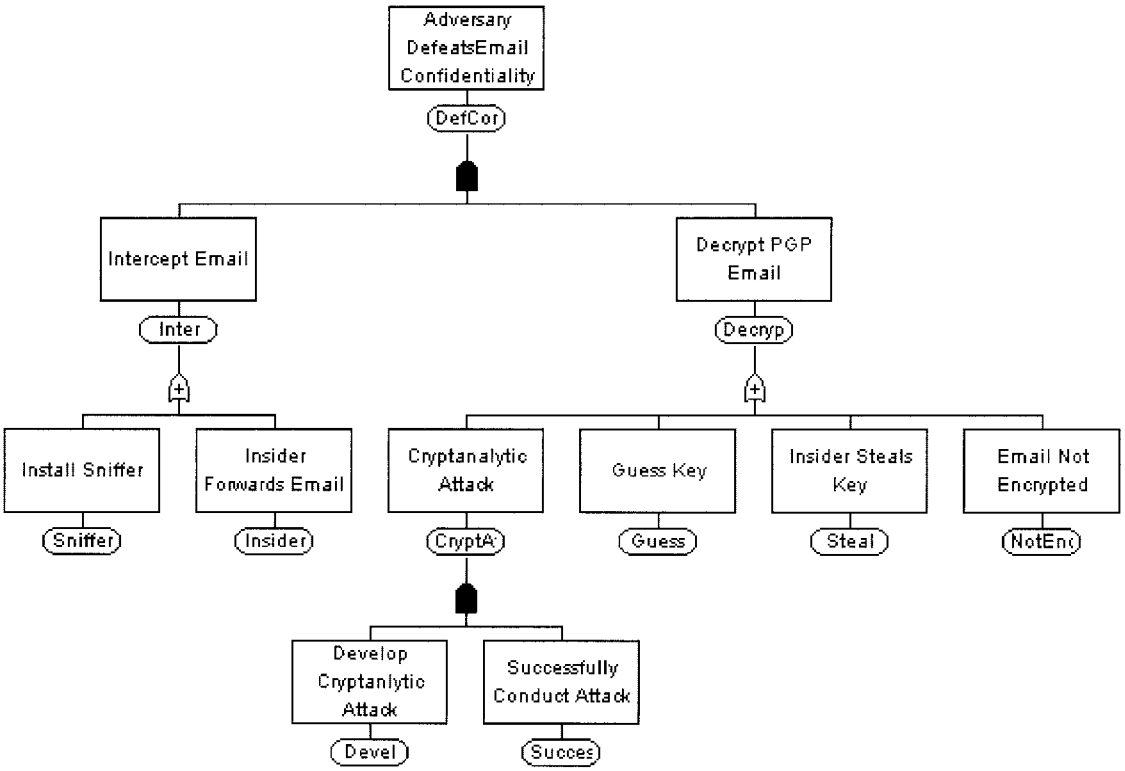



**Figure 5.** Example Attack Tree in DPLf

**Table 2.** Attack Scores for a Notional Adversary

| Attack Scoring Matrix | Adversary Value Model Measures | | |
|---|---|---|---|
| | Likelihood of Detection | Likelihood of Success | Resources Required |
| Password Attack | Low-Medium | Medium-High | Very Low |
| Buffer Overflow | Low | Very High | Very Low |
| Capture and Read Traffic | Very Low | High | Low |
| Execute a Core Dump | Low | Medium | Very Low |
| Exploit NFS Sharing | Low | Medium-High | Very Low |
| Exploit Symlink Vulnerabilities | Low | High | Very Low |
| Racing Attack | Low | Low | Very Low |
| World Writable Files | Low | High | Very Low |

documents; and risk assessments can be used. Figure 5 shows an example attack tree. Connectors with a "dot" in the middle represent "AND" relationships, while those with a "plus" represent an "OR" relationships. This tree was created using the Decision Programming Language—Fault Tree Version (DPLf) software tool (DPLf, 1998).

The DPLf tool outputs the enumerated attacks (minimum cut sets) along with attack steps that comprise them. Each attack then is scored based on its attractiveness to each adversary class. Attacks that are likely to succeed, hard to detect, require few resources, and accomplish the adversary's more highly valued goals will have high value (be more attractive). Attacks that are not likely to succeed, are easy to detect, require large amounts of resources, and do not accomplish the adversary's goals will be of low value.

Many times, the number of attacks against the system can be quite large. To make the analysis more manageable, this might require pruning the attack tree to leave the most important attacks followed by a collapsing of the remaining attacks into larger attack classes. Table 2 shows some notional scores for some larger attack classes. We scored the entire attack for simplicity.

When time permits, we score each attack step and then aggregate the attack step scores into one attack score. This is a better way to measure the effects of countermeasures but has two disadvantages. First, it puts a greater burden on data providers, easily tripling the data required. Second, it requires a theory for combining the scores of attack steps into an overall attack score. This is fairly easy to do for value measures using natural scales such as probability of success, probability of detection, or cost. In these cases, the individual attack step scores are combined using probability theory or by summing the costs and then putting the result through the value function to obtain the attack value. But for value measures using constructed scales, the analyst has to define the most appropriate aggregation function, which can be a rather daunting endeavor. But there are several attack aggregation techniques that can be used (Buckshaw et al., 2004).

## Impact of the Adversaries' Attacks

Attacks are only harmful if they impact the mission or resources of system users. Defining a mission impact model is one of the most challenging MORDA processes for two reasons. First, each system user has a different mission and users may have different ideas of how attacks can affect them. Second, system owners have a difficult time translating the results of a successful attack to the effect on the information and subsequently on the completion of the user's mission in their operational environment. In general, the impact of a successful attack can be measured using some subset of the following parameters:

- Stage of the life cycle of the system attacked
- Type of data attacked
- Amount of data attacked
- Length of the attack and time to recover

- Intensity of the attack
- Level of access achieved
- Degradation of the security service (Confidentiality, Availability, Integrity)

In Table 3, we show an example of a constructed scale for Mission Impact.

## USER AND SYSTEM PROVIDER MODELS

We use the term countermeasure to identify the solutions applied to an already fielded system. These solutions can be policy, hardware, software, or procedure options that reduce the adversary's value. On the other hand, design options are the security enhancing options analyzed for possible inclusion or exclusion in a system under design. Countermeasures applied to a system have two negative traits: they cost money, and they reduce the effectiveness to the warfighter by:

- Reducing the functionality
- Reducing the interoperability
- Reducing ease of use
- Reducing the throughput
- Delaying schedules
- And many other issues

We refer to these collective parameters as mission degradation costs (MDCs). Just as we did in the Adversary Attack model, we need to determine the fundamental objective of the system owner and the service providers.

### User Model

In this case, the system owner's fundamental objective is to "Maximize Mission Support." There are a large number of possible user objectives. Once agreed upon, these objectives form a value hierarchy as shown in Figure 6.

We asked the system architects to score the countermeasure and design options (CDOs). The architects evaluate the CDOs by the effects that they would have on the end user. CDOs that will not reduce functionality, interoperability, ease of use, and throughput received the best scores, i.e. provided the most value to the warfighter. Conversely, those that will reduce all four of these measures received the worst scores. Once we have the scores, the MDCs' value for any implemented CDO set can be calculated using the additive value function (Section 3.2).

### Service Provider Model

Other value hierarchies can exist for other stakeholders. For example, in a recent application of MORDA to a key management network design, the service providers requested that the hierarchy to assess which network design was

**Table 3.** Constructed Scale for an Availability (Denial of Service) Attack

| Mission Impact | Description | Example |
|---|---|---|
| Extreme | Impossible to use system for its wartime mission | Both communications and internal access to system denied; no good electronic back-ups exist |
| Severe | Mission is severely degraded | Mission related traffic is stopped or internal system functions stopped for several hours; cumbersome electronic back-ups exist |
| Moderate | Some mission degradation will occur | Mission related traffic is delayed for up to an hour; Mission related traffic stopped, but ready back-up communications exist |
| Minor | Only slight effect on the mission | Attack in war that noticeably slows network traffic and forces non-mission essential traffic off the network |
| Very Low | No identifiable effect on mission | Peacetime attack that reduces network bandwidth 50% for several hours |

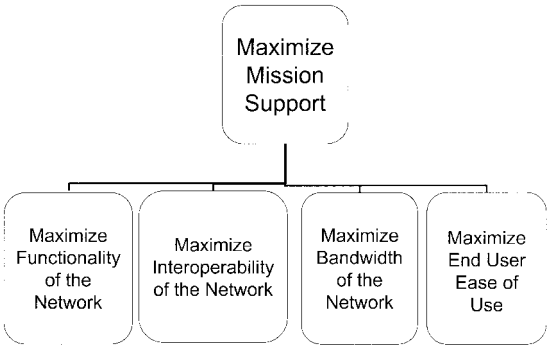



**Figure 6.** Example of Mission Owner's Value Hierarchy

the easiest to build and maintain. Their value hierarchy is shown in Figure 7.

## INTEGRATION AND ANALYSIS MODEL

MORDA has been used to recommend security fixes to an already operational system and to recommend design choices for a system under design. It has been much easier to analyze countermeasures applied to an existing system than alternative design options on a new system. This is because an operational system is defined with known operational attributes and operators with experience to help define performance and both operational and test data. But integrating security from the early stages of design is a more efficient use of resources to achieve a level of security over the system lifecycle.

## Security Related Benefits and Costs

CDOs make attacks less desirable to an adversary and therefore help to ensure mission accomplishment in a hostile environment. They typically do this by making the attack easier to detect, less likely to succeed, easier to attribute, costlier to conduct, or less harmful given success.

In Table 4, we examine a hypothetical attack on a notional network—the brute force password attack from an FIS. In the first row we score the attack on a baseline design in terms of likelihood of detection, likelihood of success, and adversary resources required. The second through sixth rows characterize the potential effects of individual countermeasures applied to the network. For example, if we choose to implement Countermeasure #1 (Auditing), we increase the likelihood of detection from the baseline score of "Low-Medium" to the new value of "High." The last column lists the financial cost of the countermeasure to the

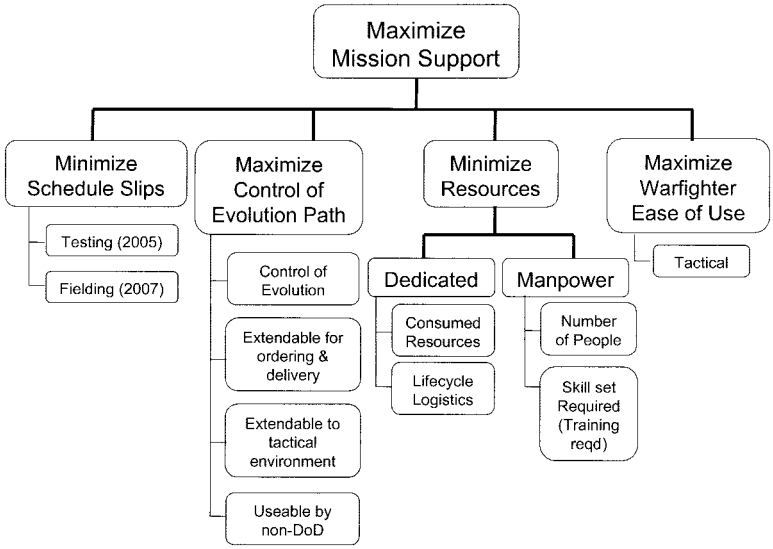



**Figure 7.** Example of Service Provider's Value Hierarchy

**Table 4.** Illustrative Attack Values for the "FIS" on Baseline System

| Attack/CDO Effect Matrix | Adversary Value Model Measures | | | Cost to US to Implement CDO |
|---|---|---|---|---|
| | Likelihood of Detection | Likelihood of Success | Adversary Resources Required | |
| Password Attack Baseline-Outsider | Low-Medium | Medium-High | Very Low | N/A |
| CDO #1 Auditing | High | No Impact | No Impact | $10,000 |
| CDO #2 Good PW Policies | Medium | Medium | No Impact | $5,000 |
| CDO #7 Install Firewall | Medium | Low | Low | $35,000 |
| CDO #8 Install VPN | Medium | Low | Low | $35,000 |
| CDO #9 Install IDS | Very High | No Impact | No Impact | $35,000 |
| Combined Effect of all CDOs | Very High | Very Low | Low | $120,000 |

network owner and will be used in the Integration and Analysis model.

We see that some countermeasures affect every one of the adversaries' objectives, while others only affect certain objectives. For example, an intrusion detection system (IDS) only increases the risk of detection but does not mitigate likelihood of success. A second countermeasure would be needed to work in concert with the IDS to mitigate likelihood of success.

The last line of the chart shows the maximum security benefit to the system if all countermeasures are used. This line demonstrates the diminishing returns to scale of additional countermeasures. It also is used to identify superior countermeasures that can completely mitigate an attack objective. For example, recall that our hypothesized adversary value function for a given attack provided a score between "0" and "1". The effect of a CDO on the attack can now be modeled as the change in value to the adversary of the attack after the countermeasure has been implemented. Other value measures, such as impact of an attack, can also be included. Mathematically, our value function for a given attack becomes:

$$\Delta v(x) = v(x) - v(x')$$

$$= \sum_{i=1}^{n} w_i(v_i(x_i) - (v_i(x_{i'}))$$

$$\Delta v(x) = w_d(v_d(x_d) - v_d(x_{d'}))$$

$$+ w_s(v_s(x_s) - v_s(x_{s'})) + w_r(v_r(x_r) - v_r(x_{r'}))$$

where

| | |
|---|---|
| $d$ | is the index for the detection value measure |
| $x_d$ | is the score of the alternative on the detection value measure without the CDO |
| $x_{d'}$ | is the score of the alternative on the detection value measure with the CDO |
| $v_d(x_d)$ | is the single dimensional value of a score of $x_d$ without the CDO |
| $v_d(x_{d'})$ | is the single dimensional value of a score of $x_{d'}$ with the CDO |
| $w_d$ | is the swing weight of the detection value measure |
| | likewise $s$ and $r$ stand for the success and resources required value measure |

This formula works well for the case where exactly one CDO affects every attack. However, we know that CDOs affect many different kinds of attacks. There may be a complex nonlinear relationship between CDOs and attack mitigation that needs to be modeled for the results of SOCRATES to be valid.

There are several ways to model this multiple CDO interaction. We could enumerate every possible countermeasure grouping and measure its benefit; however, this would make the problem intractable in all but the smallest of assessments. One modeling technique we have used is to determine the benefit of any possible CDO set by approximating the proportion of

benefit achieved between a lower and upper bound. The lower bound is the benefit gained from the "best" CDO in the candidate CDO set. The upper bound is the resulting benefit of implementing every possible CDO. The resulting benefit of any CDO set is a proportion of the benefit to be gained by moving from the lower to the upper bound.

## Financial Costs

In most design developments, there is a limit to the amount of information assurance resources that can be applied to a system. Our goal is to provide the maximum amount of benefit within these constraints. This model can also be used to justify additional funding if the system is still not sufficiently secure or not able to sufficiently support the mission given implementation of the recommended CDO set. However, getting sound financial estimates for CDOs, as well as budgetary constraints, is a challenge. One problem is that cost analysts in some organizations are asked to develop cost estimates only after a system design has been approved. But we need this data to provide the trade-offs to identify the best architecture. Often we are forced to have the system architects supply the financial cost data for these CDOs. Normally we seek financial costs for four "types" of money:

- Research
- Procurement
- Installation
- O&M

Dollar values are summed together for each CDO set to get an estimated annual cost for the 1st year and each subsequent year of the systems expected life. When financial cost in terms of dollars is not available, we can create a value model based on qualitative cost estimates.

## Risk Analysis Using the SOCRATES Model

The main benefit of our SOCRATES quantitative risk assessment model is the ability to provide insight about choices using several analytical techniques. When we have finished gathering data on the adversaries, examined the baseline architecture's vulnerabilities, scored the portfolio of attacks against the architecture, enumerated the possible CDOs and their financial costs, created a database of the CDOs' effects on the attacks and the CDOs' effect on the mission owner and system providers, we are ready to analyze the results of the models. The Adversary Attack model provides us with the value of every attack in the adversary's portfolio. These values can be analyzed to provide a description of the baseline risk to the system. The User Model provides us with an indication of how well a CDO set supports the users' ability to complete their mission. The Service Provider Model provides insight into the CDO sets that are easiest to implement and sustain.

Now we have to trade off the security related benefits of each CDO set against the mission degrading costs in order to provide the decision maker with an accurate assessment of each set's ability to support the mission in a hostile operating environment. The SOCRATES model has integrated all of this data into one large model that is flexible enough to allow several types of analyses including:

- An aggregated value model combining the individual sub-models,
- A portfolio optimization model, and
- A cost-benefit analysis.

These types of analyses will be discussed further in the next section.

*Aggregated Value Model.* The aggregation of cost and value is a topic of debate in decision analysis (Snyder, Parnell & Klimack, 2002). If the number of CDO sets under consideration is small, perhaps the simplest thing to do is to present the results as separate values. The first would be the security value from the Adversary Attack model. This value represents the proportion in value that a CDO set provides compared to the best scoring CDO set. The second value would be the User Model value. This would demonstrate how well the CDO choices support the mission of the end user. The third value would be the Service Provider Model. This would show how well the CDO choices support the architects who will build

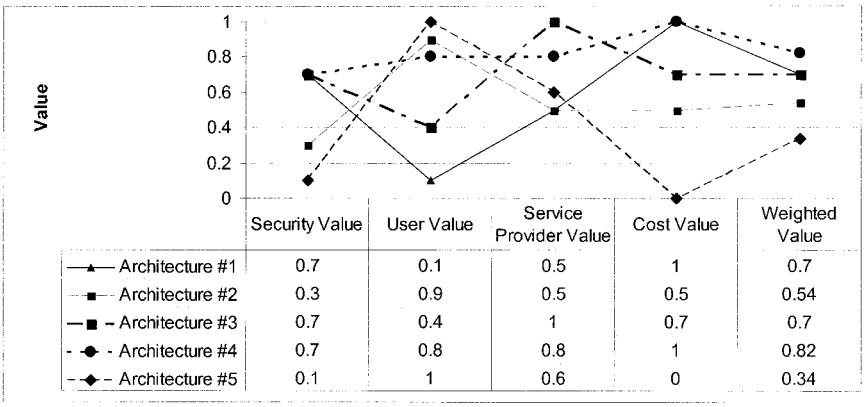
and maintain the system. In some analyses, this model has been either omitted or combined with the User Model. Lastly, the financial costs of the CDOs can be shown. These four values can stand alone individually or be presented in a weighted sum as shown in Figure 8 (weights provided in figure title). It is generally better to show both.

The plot and tabular display is fairly simple to present and understand. However, it can only be used if a few options are under consideration. We can obtain a few good options by using Value-Focused Thinking (Keeney, 1992) to design alternatives and to improve upon them. Another advantage of this technique is that concerns that were not modeled, such as schedule risk or feasibility, can be added as an additional model or used as screening criteria to eliminate undesired alternatives. This display shows whether an architecture is dominated by others or whether an architecture does not satisfy the screening criteria. For example, Architecture #4 dominates Architecture #1 since all four values are higher. Also, Architecture #5 might be screened out due to its low security value and high cost (low cost value).

*Portfolio Optimization.* If there are a large number of possible design choices, then portfolio optimization has been effectively used to select the best set of CDOs (Kirkwood, 1997). For one system's risk assessment, we were asked to review all possible combinations of 27 individual CDO choices—2^27 choices! We formulated this problem as a binary mathematical program. In order to optimize how well the CDO sets performed against each attack, we maximized the net benefit gained by trading off the weighted security benefit and mission costs. Security benefit was measured for each CDO by analyzing the change in the sum of the individual attack values in the adversary's portfolio. The mission costs were calculated for each CDO set, weighted, and subtracted from the security benefit score. We optimized system value subject to a budget constraint and a CDO compatibility constraint.

Optimization provided the best possible set of CDOs. Other possible objectives can be used, such as the reduction of risk to a pre-determined level, reduction of all attack values below a maximum value, and reducing the sum of the squares of the attack values, which has the effect of prioritizing the countermeasure set to mitigate the highest value attacks.

One way we have presented optimization results is with an attack bar chart (Figure 9). Each attack is represented by a vertical bar. The top of the stacked column represents the value of the attack to the adversary without CDOs (Attack Value Before CDOs), i.e. the baseline. A higher bar indicates a more attractive attack. The security benefit of the recommended CDO set (Attack Value Using Best CDOs) is shown as a reduction in the height of the bars. The CDOs have reduced the value of the attacks by that amount. The Attack Values Using All CDOs bar shows the complete set, i.e., the security benefit achieved by applying unlimited resources to purchase every possible CDO.




| | Security Value | User Value | Service Provider Value | Cost Value | Weighted Value |
|---|---|---|---|---|---|
| Architecture #1 | 0.7 | 0.1 | 0.5 | 1 | 0.7 |
| Architecture #2 | 0.3 | 0.9 | 0.5 | 0.5 | 0.54 |
| Architecture #3 | 0.7 | 0.4 | 1 | 0.7 | 0.7 |
| Architecture #4 | 0.7 | 0.8 | 0.8 | 1 | 0.82 |
| Architecture #5 | 0.1 | 1 | 0.6 | 0 | 0.34 |

**Figure 8.** Illustrative Architecture Values for Four Value Model and Weighted Value (Weights 0.2, 0.2, 0.2, 0.4)

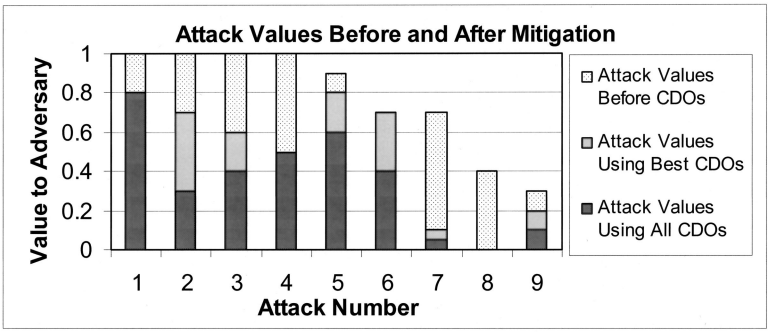



**Figure 9.** Illustrative Attack Bar Charts

In a glance, the decision-maker can see the security posture of the status quo (Attack Value Before CDOs), the recommended set (Attack Value Using Best CDOs), and the complete set (Attack Value Using All CDOs). The Attack Values Using All CDOs show the residual risk that is "unmitigatable" by candidate technology or policies. For areas with a large difference between Attack Value Using Best CDOs and Attack Values Using All CDOs, we have opted not to purchase CDOs to mitigate the attacks either because we have run out of resources, or CDOs provide too many mission degradation costs. Lastly, the Attack Values Using All CDOs, show the decision makers the potential benefit of providing resources to research new CDOs.

An optimization model has the benefit of providing the best solution. Disadvantages to optimization include long calculation times for moderate sized problems. Sometimes optimization requires special solvers for spreadsheet optimization when specialized functions introduce nonlinear functions (such as IF and MAX). Optimization can also provide an unstable solution. An unstable solution is one that significantly changes the recommended course of action given a small change in the model, such as an increase or decrease in the budget.

*Cost-Benefit Analysis.* Like portfolio optimization, a cost-benefit analysis can be helpful for analyzing a large number of CDO options. Our experience has shown that a cost-benefit analysis can solve very large number of CDO sets more efficiently than spreadsheet optimization. In traditional cost-benefit analyses, the options are considered independent of each other (Kirkwood, 1997). That is, your selection of one item does not change the value that you obtain from another item. In MORDA, the CDOs are highly dependent upon each other. Some options cannot be used if other options are selected. Also, CDOs provide diminishing returns to scale with each subsequent CDO that mitigates the same attack.

For MORDA, we developed a variant of the cost-benefit analysis named a "dependent cost-benefit analysis." In this assessment, each individual CDO is considered for its net benefit. The CDO scoring the highest (with the greatest net benefit) is placed as the first CDO in the solution. From here on, the value of any subsequent CDO is determined given that the first CDO is implemented. If a subsequent CDO does not mitigate any of the same attacks as any previous CDO, then it has full value. However, if a CDO does mitigate attacks that CDOs in the solution set already mitigate, then the CDO gets only partial credit.

Figure 10 shows a plot for a dependent cost-benefit analysis. This curve demonstrates decreasing marginal returns in value for additional CDOs. In this chart, the financial cost and mission degradation cost is included in the value of each CDO. The shape of the graph gives an indication of the level of risk associated with implementing that CDO given that you have implemented all CDOs to the left of the point. Decision makers can use the curve to identify the most appropriate allocation of resources.

The advantage of cost-benefit techniques over optimization is that they can handle larger CDO sets, have faster runs times using a

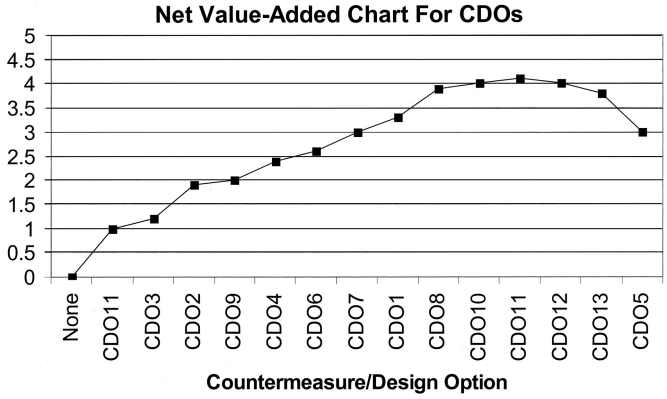



**Figure 10.** Cost Benefit Curve

spreadsheet, do not require special code, and present a stable order of implementation. The disadvantage is that this technique may not provide an optimal solution. Although the solutions may not be optimal, they have provided near optimal solutions in practice. The solutions tend to be more stable than an optimization, not changing significantly given change in the budget.

## APPLICATIONS

In its current form, MORDA has been used on seven risk assessments of critical government systems and information systems since 1998. In its nascent stages, the method was used on another six assessments. The decision maker response has been very positive. These decision makers state that for the first time they have the proper information that they need to make informed risk management decisions. Users of the system appreciate the ability to help drive design requirements and are comfortable that their concerns are important to the system architects. System architects and security experts now have a common framework and language to discuss complicated system vulnerabilities and potential countermeasures.

MORDA has been used to analyze the risks and make design recommendations for deployed communications systems, key management infrastructures, hardware and software assurance recommendations, and sensitive command and control processes. Table 5 lists these studies and shows the complexity of the models we have used. Currently MORDA is in use on the largest effort to date—the risk and design choices for the Global Information Grid.

## ADVANTAGES AND LIMITATIONS

MORDA has been used successfully on several defense-related risk assessments. Decision makers have been very pleased with the process because they believe they have the right information needed to support their risk mitigation decisions. The following are the major advantages of the MORDA process:

- Provides a process and framework for subject matter experts to communicate with each other and explicitly define model assumptions, attack data and countermeasure characterization
- Uses adversary value modeling to define system risk
- Explicitly describes every attack as a sequence of events required to complete the attack, which permits the most efficient mitigation of an attack and also provides opportunities for defense in depth
- Accounts for the complex interdependencies of countermeasures and attacks
- Compares the risk across systems
- Accounts for non-security user concerns of countermeasures, such as functionality and interoperability
- Provides a valid way of allocating mission improving resources

**Table 5.** MORDA Applications (1998 to 2004)

| Applications | Security Model | | | | User Model | Service Provider Model | Integration and Analysis Model | |
|---|---|---|---|---|---|---|---|---|
| | Scenarios | Attacks | Adversary Classes | Attributes | # of Attributes | # of Attributes | # of CDOs | Architectures |
| Multilevel Network | 1 | 10,000 | 1 | 1 | 0 | 0 | 10 | 10 |
| DoD C2 Network | 2 | 29 | 1 | 3 | 4 | 0 | 25 | 2^25 |
| Agency Software | 2 | 128 | 2 | 3 | 5 | 0 | 93 | 2^93 |
| Joint C2 | 2 | 400 | 2 | 4 | 6 | 0 | 200 | 2^200 |
| Agency Hardware | 2 | 400 | 2 | 4 | 6 | 0 | 40 | 2^40 |
| Key Management | 1 | 482 | 2 | 5 | 11 | 11 | 68 | 44 |
| Architecture Down-Select | 3 | 75 | 1 | 3 | 0 | 0 | 0 | 3 |

However, MORDA has its limitations. MORDA in its current state requires significant access to subject matter experts and a large amount of data. Data are the benefit and bane of MORDA. If time is spent to get the data required of a quantitative risk model, then one can produce insightful and clear recommendations for the decision maker. Because the data requirements are so large, we recommend that MORDA be used only on critical information systems.

## FUTURE RESEARCH

There are several areas in MORDA that require additional research. We list and briefly describe some of the most important areas.

- **Attack Aggregation.** There are several different approaches. We need to evaluate the approaches and focus on the most promising approaches (Buckshaw et al., 2004).
- **Analysis and Integration.** This is one of the most challenging computational parts of the SOCRATES model. Additional research is needed to compare the approaches that have been used and focus on improving the most promising approaches.
- **Model Validation and Verification.** SOCRATES uses models and models require validation and verification. The normal methods of validation include using actual data in the model to see if it matches ground truth. We have neither actual data nor ground truth. Another method is to use a higher fidelity validated model to see if our results are consistent. However, SOCRATES has some of the highest fidelity models in the field. Another is peer review by technical experts. We could use red teams to validate key portions of the model. The model predicts certain attack paths as being preferred and being the "least-cost." We could see if red teams behave like we predicted or come at us through surprising avenues or violate some of our adversary behavioral assumptions.
- **MORDA Learning.** The MORDA process and the SOCRATES models provide a foundation on which to build incrementally better systems design and information assurance knowledge. We should view this as an iterative process of refinement and an opportunity for learning. We need to build our theoretical and practical knowledge base as we progress from application to application. In each application we "mine" the subject matter experts to obtain the best adversary and threat knowledge possible. We need to be able to access this information and transfer our knowledge between projects.

## SUMMARY

Information systems are the fundamental enabler of our national information infrastruc-

ture and DoD's Network Centric Operations. Information assurance requires a risk assessment and risk management approach that will effectively deal with life cycle threats to information systems and information. Risk management decisions need to be made in the context of overall user alternatives.

MORDA is a systematic risk assessment and risk management process that uses state-of-the-art decision and risk analysis techniques to support national security decision makers. The purpose of MORDA is to optimize mission efficiency in a hostile and malicious operating environment. MORDA requires access to key subject matter experts to provide the technical and operational assessments required to provide an objective and credible process. The MORDA process has been very successful. The MORDA process will help provide information assurance for critical information systems and the mission essential information that will maintain the future security of our nation.

## DISCLAIMER

The views expressed in this paper are those of the authors and do not reflect the official policy or position of the United States Government or the Department of Defense.

## ACKNOWLEDGEMENTS

Special thanks to the following people who have provided an invaluable wealth of unpublished ideas, useful criticisms, helpful comments, and editing suggestions either on this paper or the model: Robin Dillon, Shelby Evans, Kristin Guimaraes, Emily Joyce, Mark Loepker, Lorin Lund, Jim Matthews, Dallas Pearson, Jim Haslup, Len Wisowaty, and many others.

## REFERENCES

Amoroso, E., 1994, *Fundamentals of Computer Security Technology*, Englewood Cliffs, New Jersey: Prentice-Hall.

Beauregard, J. E., Deckro, D. F., and Chambal, S. P., 2002, Modeling Information Assurance: An Application, *Military Operations Research*, 7 (4) 35–55.

Buckshaw, D., Buede, D., and Parnell, G., 2004, "An Analysis of Methodologies to Create a Multiple Adversary Risk Model for Information Assurance." Unpublished white paper.

Buckshaw, D., Parnell, G., Smith, G., Unkenholz, W. L., and Parks, D. L., "Comparison of Aggregation Techniques for Mission Oriented Risk and Design Analysis (MORDA) Attack Values," Innovative Decisions, Inc, Technical Report 2004-04, September, 2004.

Buede, D. M., 2000, *The Engineering Design of Systems: Methods and Models*, New York: Wiley.

Butler, S. A., May 19–25, 2002, "Security Attribute Evaluation Method: A Cost-Benefit Approach," Proceedings of the 24th International Conference of Software Engineering, Orlando, Florida.

Cohen, F., 1997, "Information System Attacks: A Preliminary Classification Scheme," Computer & Security, Vol. 16, No. 1, 1997, pp. 29–46.

Design Analysis Working Group (DAWG), National Security Agency, 2004, "*A Comparison of Risk Assessment Methodologies*," unpublished white paper.

Decision Programming Language Fault Tree Version (DPLf) User Manual, 1998, Version 4.0.

Department of Defense, 1998, Joint Chiefs of Staff, Joint Publication 3-13, Joint doctrine for Information Operations, Washington: Pentagon.

Hamill, T. J., 2000, *Modeling Information Assurance: A Value Focused Thinking Approach*, MS Thesis, AFIT/GOR/ENS/00M-15, Air Force Institute of Technology, Wright-Patterson AFB, Ohio.

Hamill, T. J., Deckro, R. F., Kloeber, J. M., Kelso, T. S., 2002, "Risk Management and the Value of Information in A Defense Computer System," *Military Operations Research*, 7 (2) 61–82.

Information Assurance Technical Framework (ITAF) Release 3.1, September 2002,

National Security Agency, Ft Meade, Maryland.

Keeney, R. L., 1992, *Value-Focused Thinking: A Path to Creative Decisionmaking*. Cambridge, Massachusetts: Harvard University Press.

Keeney, R. L., and Raiffa, H., 1976, *Decision Making with Multiple Objectives: Preferences and Value Tradeoffs*, New York: Wiley.

Kirkwood, C. W., 1997, *Strategic Decision Making: Multiobjective Decision Analysis with Spreadsheets*, Belmont, California: Duxbury Press.

Kuskey, K., 2000, Balance-Beam Scoring versus the Expert Choice Ratings Method: A Case Study, unpublished manuscript.

Lund, L., Unkenholz, W., Parks, D., Bowers, C., Brill, H., and Garner, B., 1996, "O'er the RAMparts We Watch: An Introduction to the Risk Analysis Model (RAM)," National Security Agency.

Maconachy, W. V., Schou, C. D., Ragsdale, D., and Welch, D., June 2001, "A Model for Information Assurance: An Integrated Approach," Proceedings of the 2001 IEEE Workshop on Information Assurance and Security, United States Military Academy, West Point, New York.

McClure, S. 2003. *Hacking Exposed: Network Security Secrets and Solutions*, New York, McGraw Hill.

McCumber, J., October 1991, "Information Systems Security: A Comprehensive Model." Proceedings 14th National Computer Security Conference. National Institute of Standards and Technology, Baltimore, MD.

Moore, A. P., Ellison, R. J., and Linger, R. C., March 2001, *Attack Modeling for Information Security and Survivability (CMU/SEI-2001-TN-001)*, Pittsburgh, PA: Software Engineering Institute, Carnegie Mellon University.

National Security Agency Information Assurance Solutions Technical Directors, 2002, Information Assurance Technical Framework 3.1.

Parnell, G., 2005, Draft Chapter 20—Value-Focused Thinking with Multiple Objective Decision Analysis, *Methods for Conducting Military Operational Analysis: Best Practices in Use Throughout the Department of Defense*, Military Operations Resarch Society, Forthcoming.

Salter, C., Saydjari, O., Schneier, B., and Wallner, J., September 1998, "Toward a Secure System Engineering Methodology," New Security Paradigms Workshop. Technical Report, Counterpane Systems, 101 East Minnehaha Parkway, Minneapolis, MN 55419.

Schneier, B., December 1999, "Attack Trees: Modeling Security Threats," Dr. Dobbs Journal of Software Tools 24, 12, 21–29.

Schneier, B., 2000, *Secrets & Lies: Digital Security in a Networked World*, New York: Wiley & Sons.

Soo Hoo, K. J., June 2000, "*How Much Is Enough? A Risk-Management Approach to Computer Security*." Report of the Consortium for Research on Information Security and Policy, Center for International Security and Cooperation, Stanford University, California.

Stoneburner, G., Goguen, A. and Feringa, A., 2001, *Risk Management Guide for Information Systems*, Washington D.C.: National Institute for Standards and Technology.

Snyder, F. J., Parnell, G. S., & Klimack, W. K., "Modeling the Cost Objective in Multiple Objective Decision Analysis," United States Military Academy at West Point, November 2002.

Unkenholz, Willard, 1989, *Vulnerability Tree Analysis Methodology*, Unpublished Manuscript.

Watson, S. R. and Buede, D. M., 1987, *Decision Synthesis: The Principles and Practice of Decision Analysis*, Cambridge, England: Cambridge University Press.



View publication stats